



2026 Cato CTRL™ Threat Report

Table of Contents

Foreword	3
Executive Summary	4
Chapter 1: Cato CTRL's Top Five Discoveries in 2025	5
OpenAI's ChatGPT Image Generator Enables Creation of Fake Passports	5
WormGPT Variants Powered by Grok and Mixtral	6
PoC Attack Targeting Atlassian's Model Context Protocol (MCP) Introduces New "Living Off AI" Risk	7
HashJack - Novel Indirect Prompt Injection Against AI Browser Assistants	8
From Productivity Boost to Ransomware Nightmare - Weaponizing Claude Skills with MedusaLocker	10
Chapter 2: AI Adoption in 2025	11
Chapter 3: Key Recommendations	19
Chapter 4: Conclusion	20
Methodology	20
About Cato CTRL	20
About Cato Networks	20

FOREWORD



When I observe the AI threat landscape, shadow AI is the top security risk for organizations. It is already pervasive inside organizations, driven by employees seeking productivity gains and faster results. Much like shadow IT before it, shadow AI is emerging organically, outside the boundaries of security controls, governance frameworks, and risk awareness.

Why shadow AI is different

While organizations have learned to manage shadow IT over the past decade, shadow AI introduces fundamentally higher risk. AI systems are not passive tools. They actively ingest, retain, and reason over the data they are given.

In many cases, these AI services operate under consumer-grade terms, meaning submitted data may be stored, logged, or even used for model training. This creates a scenario where sensitive data can permanently leave the organization without triggering any traditional security alert.

A path forward for enterprises

Shadow AI cannot be eliminated, but it can be managed. Effective risk reduction starts with visibility. Organizations must first understand how AI is being used across the business before applying controls.

Below are key security best practices:

- **Discover and classify AI usage** across users, applications, and data types.
- **Enable safe alternatives**, giving employees approved AI tools that meet business needs.
- **Apply granular policies**, rather than binary allow/deny decisions.
- **Educate users**, helping them understand that AI is not a neutral workplace but an external system with memory and consequences.

What this means for 2026

As AI adoption accelerates, shadow AI will become one of the most defining enterprise security challenges of 2026. The organizations that succeed will be those who treat AI as a core part of their security and risk model.

Shadow AI is a mirror of organizational behavior: where governance lags, risk fills the gap. By prioritizing visibility, context-aware controls, and shared responsibility between security and the business, enterprises can harness AI's benefits without surrendering control of their most valuable data.



Etay Maor

VP of Threat Intelligence
Cato Networks



The 2026 Cato CTRL Threat Report is the **second** annual threat report on AI security from Cato CTRL, the Cato Networks threat intelligence team.

In 2025, Cato CTRL uncovered a decisive shift in the AI threat landscape. Threat actors are no longer just exploiting AI systems. They are exploiting AI trust, workflows, and capabilities themselves. Across five major discoveries, Cato CTRL demonstrated how AI tools can be manipulated indirectly, embedded into enterprise processes, repurposed for offensive use, and abused to scale fraud and ransomware. Together, these findings show that AI has become a new attack surface that challenges security assumptions and demands AI-aware defense strategies.



AI tools are being systematically exploited

Cato CTRL revealed how threat actors are abusing implicit trust in AI systems by manipulating the data that AI consumes rather than attacking the underlying infrastructure. The discovery of HashJack, the first known indirect prompt injection technique, showed how malicious instructions can be hidden inside benign-looking URLs and executed by AI browser assistants.

Similarly, a proof-of-concept (PoC) attack against Atlassian's model context protocol (MCP) demonstrated how AI workflows that ingest external inputs (such as support tickets) can be coerced into leaking internal data. These findings expose a critical flaw: AI systems often assume inputs are safe, creating invisible attack paths that bypass traditional security controls.



Generative AI is lowering the barrier to sophisticated attacks

Cato CTRL confirmed that attack capabilities are no longer limited to highly skilled threat actors. The re-emergence of WormGPT variants powered by Grok and Mixtral illustrates how AI assistants can be stripped of safeguards and repurposed to generate phishing, social engineering content, and malicious code. In parallel, Cato CTRL demonstrated how ChatGPT's image generator can be misused to create fake passports and identity documents with minimal effort.

Overall, these discoveries highlight the accelerating commoditization of cybercrime, where AI dramatically reduces the cost, time, and expertise required to launch effective attacks.



AI tools introduce a new class of risk

As AI systems move beyond generating content to executing actions, Cato CTRL identified a growing risk of AI being embedded directly into attack chains. The weaponization of Claude Skills with MedusaLocker ransomware showed how AI automation frameworks can be leveraged to support encryption and extortion workflows. This marks a critical escalation: AI is enabling threat actors in operational stages of an attack. These findings underscore the danger of AI tools with broad permissions and insufficient oversight, particularly as enterprises increasingly integrate AI agents into business-critical processes.

In 2025, Cato CTRL published five significant discoveries in the AI threat landscape that signal a new era of cybercrime. Below is a high-level summary for each discovery.

CHAPTER 1

Cato CTRL's Top Five Discoveries in 2025



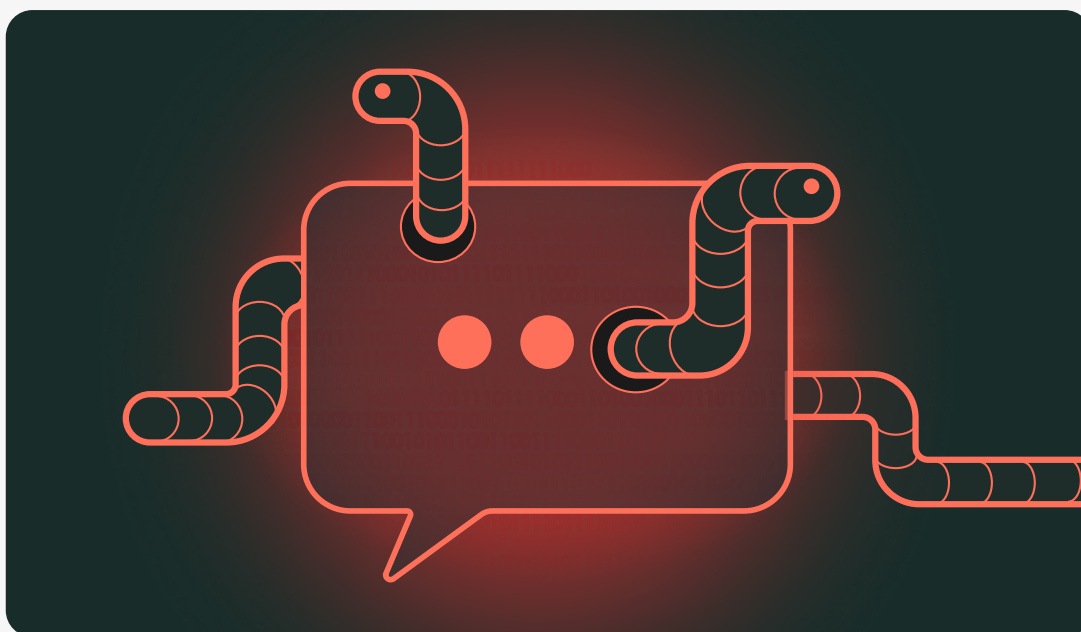
#1 | OpenAI's ChatGPT Image Generator Enables Creation of Fake Passports

On March 25, 2025, OpenAI introduced image generation for ChatGPT-4o and ChatGPT-4o mini. On March 31, 2025, it was announced that the tool was available for free to all users. Since then, users have quickly discovered that ChatGPT's image generator can be manipulated to create fake receipts and forge other documents.

As noted in the 2025 Cato CTRL Threat Report, the emergence of generative AI (GenAI) tools like ChatGPT is democratizing cybercrime and creating a major shift in the threat landscape. This is known as the rise of the "zero-knowledge threat actor." At Cato CTRL, we have discovered that fake identity documents like passports can be created in minutes with ChatGPT's image generator. No jailbreak is required. Just a few prompts.

Organizations must update their fraud detection mechanisms, not just for traditional phishing and malware, but for document-based attacks as well.

For the full findings, [read the blog](#) ↗



#2 | WormGPT Variants Powered by Grok and Mixtral

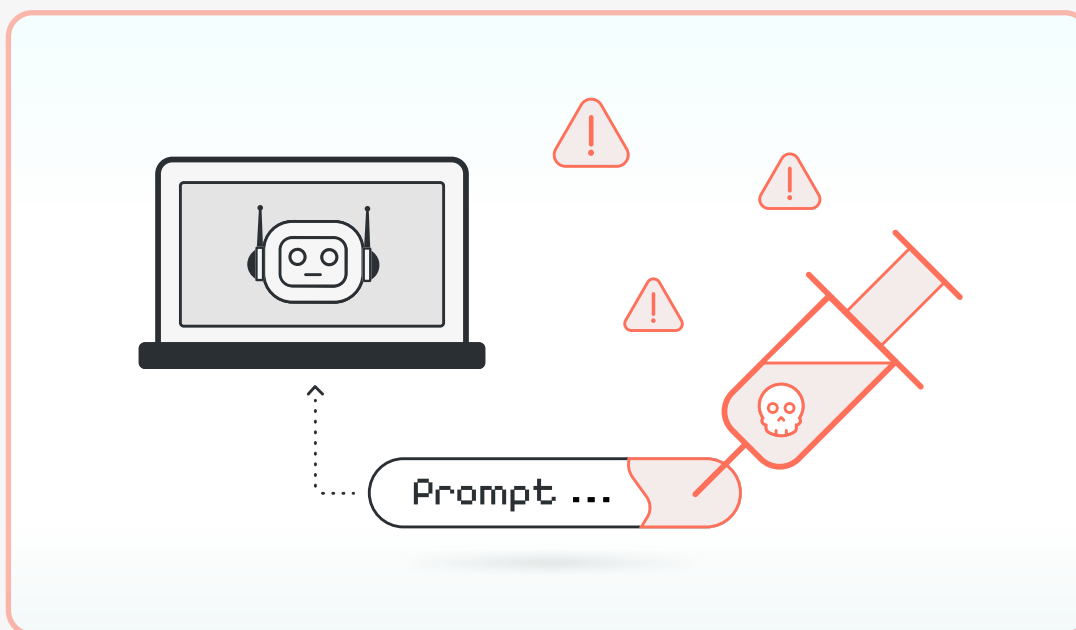
When large language models (LLMs) became popular following OpenAI's public release of ChatGPT in November 2022, threat actors understood the potential of such systems and how they can be used in their malicious operations. However, the main challenge that threat actors encountered a couple of years ago is that the LLMs were censored and didn't allow the creation of malicious content.

Enter WormGPT.

WormGPT emerged in June 2023 on Hack Forums, a popular underground forum, as an uncensored GenAI tool. WormGPT facilitated black hat activities for threat actors. However, in August 2023, WormGPT was shut down by one of the creators.

Since then, WormGPT variants have emerged in BreachForums, another popular underground forum. As part of our analysis, Cato CTRL has discovered previously unreported WormGPT variants that are powered by xAI's Grok and Mistral AI's Mixtral.

For the full findings, [read the blog](#) ↗



#3 | PoC Attack Targeting Atlassian's Model Context Protocol (MCP) Introduces New “Living Off AI” Risk

Most organizations assume a clear boundary between external users, who submit support tickets or service requests, and internal users, who handle them using privileged access. However, when an internal user triggers an AI action from an MCP tool, such as summarizing a ticket, that boundary can break. The AI action is executed with the internal user's permissions (whether a human agent, a bot, or an automated integration), meaning a malicious ticket submitted by an external threat actor can be used to inject harmful instructions.

Here's how it works:

- A threat actor (acting as an external user) submits a malicious support ticket.
- An internal user, linked to a tenant, invokes an MCP-connected AI action.
- A prompt injection payload in the malicious support ticket is executed with internal privileges.
- Data is exfiltrated to the threat actor's ticket or altered within the internal system.
- Without any sandboxing or validation, the threat actor effectively uses the internal user as a proxy, gaining privileged access.

We demonstrate a PoC attack targeting Atlassian's MCP and Jira Service Management (JSM). We refer to this as a “Living Off AI” attack. Any environment where AI executes untrusted input without prompt isolation or context control is exposed to this risk.

Cato's customers can define security rules to inspect and control AI tool usage across an enterprise environment with GenAI security controls from [Cato CASB](#).

For the full findings, [read the blog](#) ↗



#4 HashJack - Novel Indirect Prompt Injection Against AI Browser Assistants

HashJack is a newly discovered indirect prompt injection technique that conceals malicious instructions after the # in legitimate URLs. When AI browsers send the full URL (including the fragment) to their AI assistants, those hidden prompts get executed. This enables threat actors to conduct a variety of malicious activities. Cato CTRL's findings outline six scenarios including callback phishing, data exfiltration (in agentic modes), misinformation, malware guidance, medical harm, and credential theft.

What we found

HashJack is the first known indirect prompt injection that can weaponize any legitimate website to manipulate AI browser assistants. As a result, AI browsers including Comet (Perplexity), Copilot for Edge (Microsoft), and Gemini for Chrome (Google) can be used to enable a wide range of malicious attacks.

How it works

HashJack enables threat actors to conceal malicious prompts after the “#” symbol within legitimate URLs. When an AI browser loads a page and the user interacts with the AI assistant, these hidden prompts are fed directly into LLMs. In agentic AI browsers like Comet, the attack can escalate further, with the AI assistant automatically sending user data to threat actor-controlled endpoints.

Why it works

HashJack works by abusing user trust. Because the malicious fragment is embedded in a real website's URL, users assume the content is safe while hidden instructions secretly manipulate the AI browser assistant.

Why does this matter:

- **Invisible payloads**

URL fragments never leave the AI browser, so traditional network and server defenses don't see them.

- **Abuses trust**

Users increasingly rely on AI browser assistants for quick actions and advice, and users trust the legitimate website they interact with as opposed to a phishing website.

- **Any website can be weaponized**

Threat actors don't need to compromise the site itself. The weakness lies in the AI browser's handling of URL fragments.

Cato mitigations

While HashJack is a client-side attack, Cato mitigates many of its downstream effects including phishing, malware delivery, and abnormal data flows through [CASB](#), [NGAM](#), and [IPS](#) protections within the [Cato SASE Platform](#).

For the full findings, [read the blog](#) ➞



#5 | From Productivity Boost to Ransomware Nightmare - Weaponizing Claude Skills with MedusaLocker

Claude Skills is a new feature from Anthropic that has gained rapid adoption, with more than 77,000+ [GitHub stars](#) at time of writing since its [launch](#) in October 2025, allowing users to create and share custom code modules that expand Claude’s capabilities and streamline workflows. But as this ecosystem grows, Cato CTRL uncovered a serious oversight into how Skills are executed.

With minimal modification, a seemingly legitimate Skill can be weaponized to execute ransomware, without the user’s explicit awareness. Our research shows that it takes only minor edits to a legitimate Skill to enable silent malicious behavior, all while appearing completely legitimate.

Even in Claude’s strictest security mode, users see clear approval prompts and reviewed code that looks safe. But that visibility covers only part of what runs. Behind those reassuring confirmations, additional operations (legitimate or not) can still be executed under the same approval, creating a false sense of safety

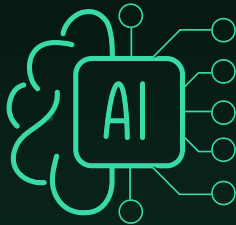
Cato CTRL weaponized Claude Skills in a controlled test environment to execute a live MedusaLocker ransomware attack, demonstrating how a trusted Skill could trigger real ransomware behavior end-to-end under the same approval context. Because Skills can be freely shared through public repositories and social channels, a convincing “productivity” Skill could easily be propagated through social engineering, turning a feature designed to extend your AI’s capabilities into a malware delivery vector.

With Anthropic [serving more than 300,000 business customers](#), many with enterprise-wide rollouts, there is potential for a large-scale ransomware attack. One convincingly packaged malicious Claude Skill, installed and approved once by a single employee, could trigger a multimillion-dollar ransomware incident. According to [IBM’s Cost of a Data Breach Report 2025](#), the average cost of a ransomware incident is \$5.08 million.

For the full findings, [read the blog](#) ↗

CHAPTER 2

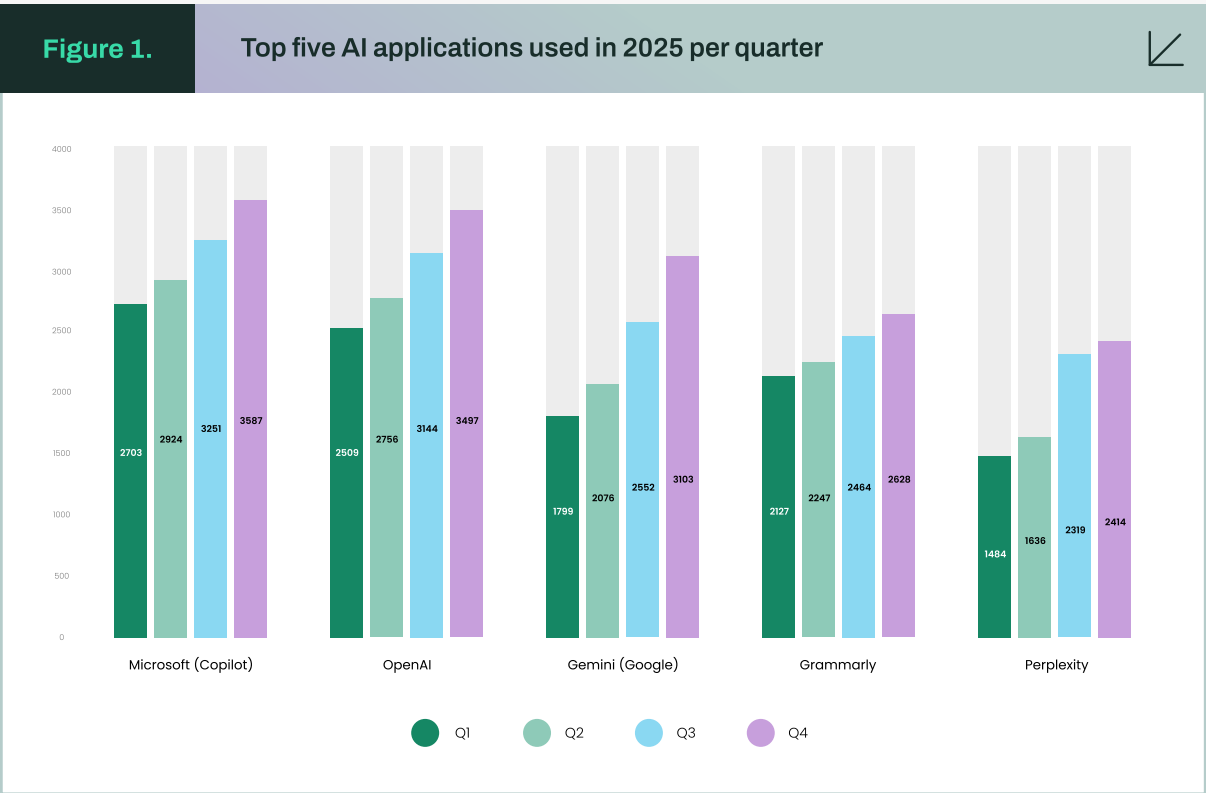
AI Adoption in 2025



Cato CTRL has visibility into the usage of AI applications within corporate networks. Out of the hundreds of AI applications that Cato CTRL monitors, we provide a breakdown of the top AI applications used by organizations.

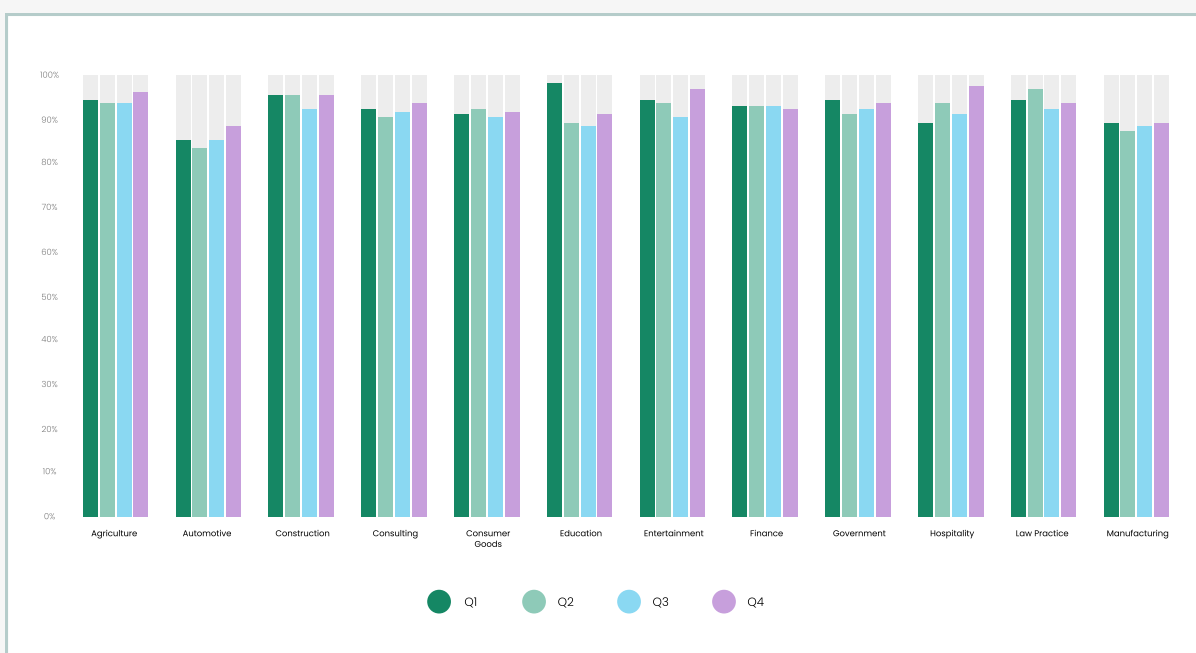
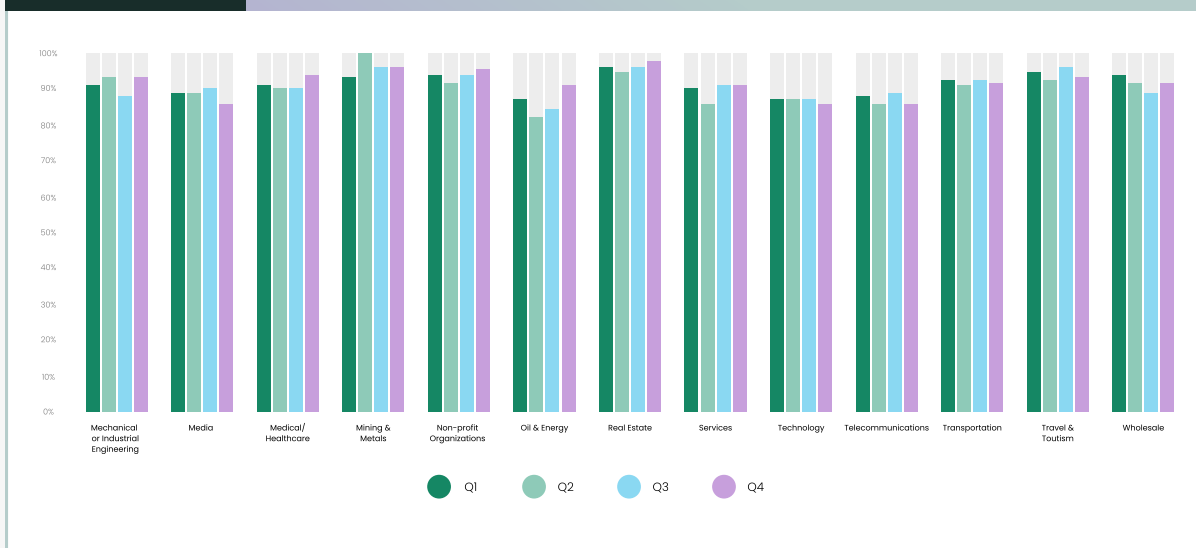
As shown in Figure 1, Copilot (Microsoft), OpenAI, Gemini (Google), Grammarly, and Perplexity ranked as the top five AI applications in 2025. Copilot, OpenAI, Gemini, Grammarly, and Perplexity all increased in adoption from Q1 2025 to Q4 2025 by 33%, 39%, 72%, 24%, and 63% respectively.

All five applications showed consistent quarter-over-quarter growth, reflecting broadening enterprise adoption of AI tools.



Figures 2 & 3.

AI application usage in 2025 by vertical per quarter



AI adoption is effectively universal across all industries, with 20 out of 25 verticals showing adoption rates of 90% or higher by Q4 2025. The average adoption rate across all industries remained consistently above 90% throughout the year, reaching 92% in Q4 2025.

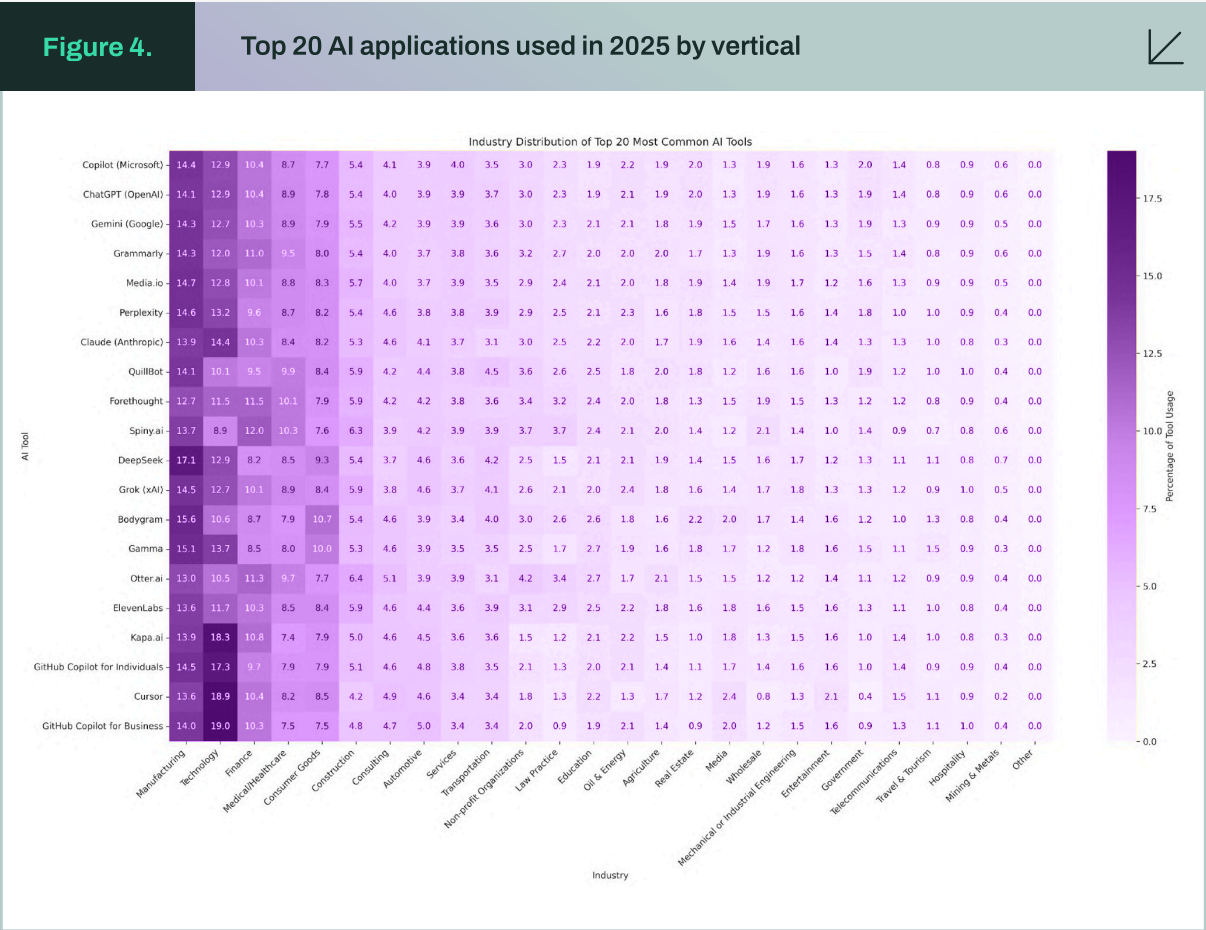
Notably, technology (86%), telecommunications (86%), and media (86%) rank among the lowest AI adopters. This is a counterintuitive finding that likely reflects stricter corporate IT governance and sanctioned tooling policies in these industries, which suppress the use of consumer-grade AI tools visible in network traffic. Even the lowest-adopting industry never dipped below 82% (oil & energy in Q2 2025), underscoring that AI tool usage has become a baseline reality for security teams to address regardless of vertical. The data also reveals that adoption has plateaued rather than surged: most industries fluctuated within a narrow 2-3 percentage point band across all four quarters, indicating that organizations that were going to adopt AI tools have already done so, and the challenge has shifted from preventing adoption to governing it.

In Figure 4 below, we created a heatmap to show the usage of the top 20 AI applications across verticals in 2025. Fifteen of the top 20 tools have manufacturing as their top industry.

The clearest exceptions are developer-focused tools (Cursor, GitHub Copilot for Business and GitHub Copilot for Individuals, and Kapa.ai), where the technology industry accounts for the majority of usage. Claude (Anthropic) also skews toward technology (14.4%) as its top industry.

DeepSeek stands out with an unusually high manufacturing share (17.1% vs. the 14.3% average), while Bodygram shows a notable tilt toward consumer goods (10.7% vs. the 8.3% average).

Overall, the uniformity of the heatmap underscores that the most widely adopted AI tools are horizontal in nature. Enterprises across all verticals are embracing the same set of tools at similar rates.



Security risks for the top 20 AI applications used

General-Purpose AI Assistants

App Name	Description	AI Usage	Security Risk
Copilot (Microsoft)	AI assistant integrated into Microsoft 365 and Bing.	Task automation, coding help, document summarization, and image generation.	Copilot inherits existing Microsoft 365 access permissions, meaning years of accumulated oversharing in Microsoft SharePoint and Microsoft Teams can suddenly become queryable by any employee in natural language. Sensitive HR files, executive compensation data, or legal-privileged documents that were technically accessible but practically hidden are now one prompt away. Organizations must audit and remediate permission sprawl before Copilot deployment. A zero-click prompt injection vulnerability (CVE-2025-32711) discovered by Aim Security demonstrated that even without employee action, threat actors can silently retrieve internal data.
ChatGPT (OpenAI)	Conversational AI for text generation and analysis.	Natural language processing (NLP) for drafting, coding, data analysis, and brainstorming.	ChatGPT is a popular unsanctioned AI tool in the enterprise. The core risk is that employees routinely paste proprietary source code, financial data, legal documents, and personally identifiable information (PII) into a consumer tool where free-tier inputs may be used for model training. This is not theoretical. Samsung engineers leaked semiconductor source code through ChatGPT while debugging. Organizations that have not deployed an enterprise-tier alternative should assume sensitive data is already flowing to OpenAI's consumer platform.
Gemini (Google)	Google's multimodal AI assistant integrated into Google Workspace.	Text, image, and video understanding across Gmail, Google Docs, Google Calendar, and Google Drive.	For organizations running Workspace, Gemini has broad access to Gmail, Docs, Calendar, and Drive. This creates a large AI-accessible attack surface: the GeminiJack vulnerability discovered by Noma Security demonstrated that a single poisoned Google Doc shared with an employee could silently instruct Gemini to search across all Workspace data and exfiltrate it externally without any clicks or alerts. Enterprises must treat every shared document as a potential prompt injection vector and evaluate whether Gemini's Workspace access scope matches their data classification policies.
Perplexity	AI-powered search engine with cited answers.	Research, competitive intelligence, and natural language question-answering.	Employees use Perplexity for research by pasting internal context into queries—such as competitive pricing, product roadmaps, or financial projections—to get better answers. This creates an external, searchable record of corporate strategy on a third-party platform. Perplexity's Comet browser can also read content from open browser tabs, meaning internal dashboards and web-based tools open alongside Perplexity may be passively ingested. Free-tier queries are retained and used for model improvement.
Claude (Anthropic)	Advanced conversational AI for analysis and instruction-following.	Complex document analysis, code review, brainstorming strategy, and problem-solving.	Claude offers enterprise-grade controls (SOC 2 Type II and ISO 27001) on its enterprise and API tiers, but the primary risk is the gap between sanctioned and unsanctioned usage. Employees on free or pro consumer accounts submit sensitive documents for analysis, and since September 2025, consumer-tier inputs are used for model training by default unless manually opted out. An organization may have a secure Claude Enterprise deployment while employees simultaneously route confidential data through personal accounts that lack every protection the enterprise tier provides.

App Name	Description	AI Usage	Security Risk
DeepSeek	Chinese-developed LLM and chatbot.	Free alternative to ChatGPT for drafting, coding, and data analysis.	Any data entered into DeepSeek is stored on servers in China, where national intelligence law allows the government to compel data handover on demand. For enterprises, this means any proprietary code, financial data, or strategic documents that employees paste into DeepSeek could be accessible to Chinese intelligence services. The platform has also demonstrated fundamental security failures—Wiz <u>discovered</u> an exposed database that leaked over 1 million user chat histories in plaintext—and the app transmits data without proper encryption. Despite being banned by NASA, the Pentagon, and multiple governments, employees continue to use it as a free ChatGPT alternative.
Grok (xAI)	AI chatbot on the X (Twitter) platform.	Quick research, content drafting, and social media analysis via X accounts.	Grok is embedded in X, meaning employees using corporate or personal X accounts are interacting with it. This is often without realizing their posts and interactions are being used to train the model by default. Since November 2024, non-EU users cannot opt out. For enterprises managing brand accounts on X, all social media activity is feeding Grok's training data. Additionally, Grok's conversation-sharing feature <u>led to over 370,000 private chats being indexed by search engines</u> , demonstrating that any sensitive query entered into Grok could become publicly discoverable.

Writing, Content & Presentation Tools

App Name	Description	AI Usage	Security Risk
Grammarly	AI writing assistant with browser extension and desktop application.	Grammar checking, tone adjustment, and rewriting across emails, documents, and messaging.	Grammarly's browser extension processes all text typed in browser fields (emails, Slack messages, CRM entries, and internal wikis) by transmitting it to external servers for analysis. Unlike tools where employees deliberately paste content, Grammarly captures data passively and continuously. For enterprises without a managed Grammarly deployment, every employee who installs the free extension creates an unmonitored data egress channel that bypasses data loss prevention (DLP) controls entirely. Grammarly is ranked as the most privacy-invasive AI-powered Chrome extension in a January 2026 <u>report</u> by Incogni.
QuillBot	AI paraphrasing and rewriting tool.	Paraphrasing, summarizing, and rewriting text for reports and communications.	Employees paste internal documents (strategy memos, legal drafts, and performance reviews) into QuillBot to rewrite them for different audiences. Since November 2025, QuillBot's browser extension silently stores all text inputs by default, reversing its previous opt-in consent model. The extension holds broad permissions to read and inject code into any webpage. There is no enterprise tier, no SOC 2 certification, and no organizational controls available. For enterprises, QuillBot represents a blind spot: a consumer writing tool that employees view as harmless but that silently exfiltrates the full text of everything they rewrite.

App Name	Description	AI Usage	Security Risk
Gamma	AI-powered presentation and document creation tool.	Generates polished slide decks from pasted text, notes, or raw data.	Gamma's core workflow requires employees to paste raw content (revenue figures, product roadmaps, and customer data) into a consumer AI tool to generate presentations. Beyond the data exposure risk, Gamma has been actively weaponized against enterprises: in April 2025, Abnormal AI discovered threat actors could host phishing documents on Gamma's trusted domain to harvest Microsoft 365 credentials, bypassing email security filters (SPF, DKIM, and DMARC) because Gamma is a legitimate platform. This means Gamma links in employee inboxes may be either legitimate presentations or credential-harvesting attacks, and traditional email security cannot distinguish between the two.

Media, Voice & Biometric Tools

App Name	Description	AI Usage	Security Risk
Media.io	AI-powered media editing tool.	Audio/video conversion, noise removal, and AI-enhanced media editing.	Employees upload corporate media (training videos, marketing assets, and executive recordings) to Media.io's cloud for processing. The parent company Wondershare has demonstrated systemic security failures: two critical vulnerabilities discovered by Trend Micro revealed hardcoded cloud credentials exposing customer data, AI models, and signed executables. This enabled a full supply-chain attack where tampered updates could be pushed to all customer endpoints. Wondershare was unresponsive to responsible disclosure for five months. Any Wondershare product should be treated as an elevated vendor risk.

ElevenLabs	AI voice generation and cloning platform.	Text-to-speech, and voice cloning for marketing content and training materials.	ElevenLabs can clone any voice from a short audio sample, which means every executive whose voice is publicly available (from earnings calls, conference talks, or podcasts) is a potential target for AI-powered vishing attacks. For example, a deepfake voice was used by fraudsters to authorize a \$25M wire transfer from a company in early 2024 . Internally, employees who clone executive voices for legitimate content (training and marketing) create persistent voice models that ElevenLabs retains indefinitely under its terms of service (ToS). In February 2024, the FCC declared AI-generated voice robocalls illegal specifically because of an ElevenLabs-attributed deepfake of President Joe Biden was used for U.S. voter suppression.
------------	---	---	--

Bodygram	AI body measurement application using smartphone photos.	3D body measurement from photos for corporate wellness or uniform sizing.	Enterprises deploying Bodygram for wellness programs or uniform sizing are collecting biometric data (body photographs and physical dimensions) that trigger regulatory obligations under BIPA, GDPR Article 9, and emerging state biometric laws. Individual BIPA settlements have reached hundreds of millions of dollars including Meta's \$650M settlement in 2020. Unlike passwords or tokens, compromised biometric body data cannot be reset or reissued. Organizations must ensure explicit written consent, defined retention schedules, and data destruction policies before any deployment or face the same class-action exposure that cost Clearview AI \$51.75M and Google \$1.375B in biometric settlements in 2021 and 2025, respectively.
----------	--	---	---

Developer & Code Tools

App Name	Description	AI Usage	
GitHub Copilot for Individuals	AI code completion (individual/free plan).	Auto-completing code, generating functions, and suggesting solutions in IDEs.	When developers use personal Copilot subscriptions on corporate codebases, proprietary source code is sent to GitHub's servers for inference with no organizational visibility, audit logging, or content exclusion controls. The individual plan may also share code snippets for product improvement by default. For enterprises, the risk is straightforward: developers on personal plans are an invisible, uncontrolled channel through which proprietary code and embedded secrets flow to external infrastructure.
GitHub Copilot for Business	AI code completion (business/enterprise plan).	Same as GitHub Copilot for Individuals, with admin controls, policy management, and intellectual property (IP) indemnification.	The Business plan addresses shadow AI concerns by providing admin controls, audit logging, and a contractual commitment not to train on customer code. However, source code is still transmitted to GitHub for real-time inference. The content exclusion feature requires proactive configuration and may miss sensitive code referenced via imports. Copilot can also suggest insecure patterns or hallucinated package names that threat actors register as malicious (dependency confusion). Organizations should treat GitHub Copilot for Business as a managed risk with proper guardrails, not a risk-free deployment.
Cursor	AI-powered code editor.	AI-assisted code editing, refactoring, and generation with full codebase context.	Developers grant Cursor full access to their entire codebase for context-aware AI suggestions, making a compromised Cursor instance a single point of exposure for all source code. Without Privacy Mode (off by default), Cursor stores codebase data and may use it for model training. There is no on-premise deployment option. In 2025, Aim Security <u>discovered</u> a high severity vulnerability in Cursor that enables remote code execution (RCE).
Kapa.ai	AI documentation assistant for developer tools.	Answers developer questions by indexing internal docs, APIs, and codebases	Kapa.ai indexes internal documentation sources (such as Confluence, GitHub, Jira, and Zendesk) to power developer-facing Q&A chatbots. The enterprise risk is in data boundary misconfiguration: if internal docs containing architecture details, API specifications, infrastructure descriptions, or credentials pasted into tickets are indexed, that content could be surfaced through a public-facing chatbot to external users. Organizations must carefully audit which data sources are connected and enforce strict access boundaries between internal and external-facing Kapa instances.

Meeting, Support & Analytics Tools

App Name	Description	AI Usage	
Forethought	AI-powered customer support automation platform.	Automated ticket triage, response generation, and knowledge base management.	Forethought processes customer support tickets that routinely contain PII, account credentials, financial details, and health information. The AI's automated PII redaction operates on a "best effort" basis, meaning non-standard formats or non-English data may pass through unredacted into the ML pipeline. Organizations should test PII redaction rather than relying on vendor claims, and ensure prompt injection defenses are in place for any AI system processing unstructured customer input.
Spiny.ai	AI analytics platform for digital media publishers.	Revenue analytics, audience intelligence, and content performance prediction.	Spiny.ai provides revenue and editorial analytics for digital publishers, ingesting ad revenue breakdowns, audience demographics, content performance metrics, and traffic source data. The enterprise risk is in data ownership: Spiny's terms of service state that the company owns "all data other than Your Data, including any system generated data generated by the Services or any data compiled from data inputted into the Services by all Users on an aggregate basis," and may use this data "in any way it chooses including to improve or adapt its services, or to create or design new products and services." This contractual language means a publisher's revenue figures and audience data could theoretically be repackaged into aggregate products accessible to competitors. Organizations should negotiate explicit data ownership and usage restrictions contractually before onboarding.
Otter.ai	AI meeting transcription and note-taking tool.	Auto-joins meetings, transcribes conversations, and generates summaries and action items.	Otter.ai is one of the most dangerous shadow AI tools because it captures verbatim transcripts of the most sensitive enterprise discussions including M&A deliberations, legal strategy, personnel reviews, and board conversations. It auto-joins meetings via calendar integration without obtaining consent from other participants, creating wiretapping liability in two-party consent jurisdictions. In a documented 2024 incident, Otter transcribed a post-meeting investor discussion and sent it to the opposing party, collapsing the deal. A class-action lawsuit in August 2025 alleges recordings are used for AI model training without disclosure, meaning confidential enterprise conversations may influence outputs served to other customers.

CHAPTER 3

Key Recommendations



Cato CTRL's discoveries in 2025 demonstrate that AI introduces new attack surfaces that extend beyond traditional networks. Security practitioners must adapt controls, monitoring, and governance to account for AI systems that ingest untrusted inputs, generate content at scale, and execute actions autonomously. The following recommendations outline practical steps to reduce risk across the AI threat landscape.

Treat AI Inputs as Untrusted Data by Default

- Apply input validation, sanitization, and context isolation to all data ingested by AI tools, including metadata, URLs, and file fragments.
- Enforce content inspection and classification before AI systems process external inputs.
- Assume that indirect or hidden instructions may exist in otherwise benign content.

Extend Security Monitoring into AI Workflows

- Monitor AI interactions, prompts, responses, and downstream actions for anomalous behavior.
- Correlate AI activity with user behavior, network traffic, and application logs to identify abuse patterns.
- Alert on unexpected data access, abnormal output generation, or unusual task execution by AI systems.

Govern and Control Enterprise AI Usage

- Discover and inventory AI services in use across the organization, including browser-based and embedded tools.
- Define and enforce AI usage policies aligned with risk tolerance and regulatory requirements.
- Regularly review AI integrations as part of security architecture and risk assessments.

Enforce Least Privilege and Guardrails for AI Agents and Automations

- Apply strict least-privilege access to AI tools, restricting them to only the data and actions required.
- Separate read, write, and execution privileges and avoid broad, persistent permissions.
- Require human approval or policy checks for high-risk AI actions, such as data exports, system changes, or workflow execution.

Address AI-Enabled Social Engineering and Identity Abuse

- Strengthen identity verification, document validation, and anomaly detection processes.
- Avoid relying solely on visual or content-based trust signals.
- Train users to recognize AI-assisted deception and enforce out-of-band verification for sensitive requests.

CHAPTER 4

Conclusion

Methodology

The 2026 Cato CTRL Threat Report summarizes findings from Cato CTRL's analysis of 6.7 trillion network flows across more than 4,000 customers globally in 2025.

About Cato CTRL

Cato CTRL (Cyber Threats Research Lab) is the world's first CTI group to fuse threat intelligence with granular network insight, made possible by Cato's global SASE platform. By bringing together dozens of former military intelligence analysts, researchers, data scientists, academics and industry-recognized security professionals, Cato CTRL utilizes network data, security stack data, hundreds of security feeds, human intelligence operations, AI (Artificial Intelligence), and ML (Machine Learning) to shed light on the latest cyber threats and threat actors.

About Cato Networks

Cato Networks, a leader in SASE and AI security, delivers secure, zero-trust access everywhere to thousands of customers worldwide. Built for organizations operating across all cloud and hybrid environments, the Cato SASE Platform unifies networking, security, and access, providing them as elastic, modular capabilities that organizations can easily adopt and grow over time. Cato combines the Cato Cloud, a purpose-built global network, with simplified operational experience, all delivered across a robust, AI-driven platform. With Cato, organizations modernize confidently, operate with greater resilience, and innovate faster, without added complexity or risk.

Want to learn why thousands of organizations secure their future with Cato? Visit us at www.catonetworks.com.